

interactive compliance repository

HR Data Privacy Compliance Tracker GDPR Across EU Member States

A GDPR HR Data Privacy
Compliance Audit Across

8 EU Member States

Recruitment · Biometric · Monitoring ·
Health Data · Performance · Payroll

Prepared by	Ayaan Alam
Jurisdictions	8 EU Member States
Report Date	June 2026
Real Cases	7 Enforcement Actions
Deliverable	Power BI Compliance Dashboard

KEY FINDINGS AT A GLANCE

Highest Compliance Risk Score

5.0 / 5

France — pre-approval
licensing regime

Largest Single Fine Identified

€2.0M

Spain — unlawful criminal record
checks

Total Fine Value Mapped	€3.17M
Countries Rated Critical	2 of 8
Retention Period Range	21 days – 7 yrs
Countries w/ Zero Fines	3 of 8 (guidance-led)

Compiled from EDPB guidance, national DPA rulings,
and 7 real enforcement cases across 8 EU member states.
Data collected manually, June 2026.

Contents

1	Executive Summary	3
2	Methodology & Scope	4
2.1	Audit Scope	4
2.2	Data Sources	4
2.3	Analytical Framework: The Compliance Risk Score	4
3	Compliance Risk Score — All 8 Countries	5
4	Category Deep-Dive: Biometric Data	6
5	Category Deep-Dive: Employee Monitoring	7
6	Category Deep-Dive: Health Data & Recruitment	8
6.1	Health/Sickness Data — Netherlands	8
6.2	Recruitment Data — Spain, Poland, Germany	8
7	Category Deep-Dive: Performance Records & Payroll	9
7.1	Performance & Disciplinary Records — Italy	9
7.2	Payroll & Financial Data — Netherlands	9
8	Retention Period Benchmark	10
9	Power BI Dashboard Overview	11
10	Strategic Recommendations	12
10.1	For a Company Operating HR Systems Across These 8 Countries	12
11	Limitations & Conclusion	13
12	Appendix: Complete Data Repository	14

1 Executive Summary

This repository maps GDPR compliance requirements for HR data processing across eight EU member states — Germany, France, the Netherlands, Ireland, Spain, Italy, Poland, and Sweden — spanning six HR data categories: recruitment, biometric data, employee monitoring, health/sickness data, performance records, and payroll data.

Central Finding: GDPR is a single EU-wide regulation, but Article 9(4) explicitly permits member states to layer their own national rules on top of it for sensitive data categories. The result is not one law but eight functionally different compliance regimes — ranging from France’s pre-approval licensing model to Ireland’s guidance-only, low-enforcement approach.

Five Headline Statistics

Metric	Finding
Highest Risk Jurisdiction	France (5.0/5) — pre-approval licensing for biometric data
Lowest Risk Jurisdiction	Ireland (1.3/5) — guidance-led, no HR-specific fines found
Largest Single Fine	€2,000,000 — Spain, unlawful criminal record checks
Retention Period Range	21 days (Italy, email metadata) to 7 years (Netherlands, payroll)
Countries with Zero HR Fines Found	3 of 8 (Poland, Sweden, Ireland) — guidance-led jurisdictions

Why This Matters: Any company operating HR systems across multiple EU countries — payroll platforms, biometric attendance, monitoring software, applicant tracking — cannot apply one compliance policy uniformly. A practice that is fully lawful in Ireland (covert-adjacent monitoring with a documented legitimate-interest test) can trigger a six-figure fine in France or the Netherlands.

2 Methodology & Scope

2.1 Audit Scope

1. **Country Selection (8):** Germany, France, Netherlands, Ireland, Spain, Italy, Poland, Sweden — chosen for enforcement intensity (Germany, France, Netherlands), Big Tech HQ concentration (Ireland), regional representation (Spain, Italy, Poland), and transparency-led regulatory culture (Sweden).
2. **HR Data Categories (6):** Recruitment data, biometric data, employee monitoring, health/sickness data, performance & disciplinary records, payroll/financial data.
3. **Per-Entry Fields Tracked:** Legal basis, retention period, special-category status (Article 9), consent validity, local derogation, and source citation.
4. **Analytical Layer:** A weighted Compliance Risk Score (0–5) combining enforcement strictness, derogation complexity, and documentation burden — enabling direct cross-country comparison.

2.2 Data Sources

Source	Used For
European Data Protection Board (EDPB)	Official EU-level guidance on employment data processing
National DPA rulings (CNIL, AEPD, Garante, AP, DPC, IMY, UODO, BfDI)	Country-specific enforcement actions, fines, and guidance
gdpr-info.eu	Plain-text GDPR articles, including Article 9 (special category data)
Legal commentary (Lexology, Taylor Wessing, Osborne Clarke)	Country-law context (BDSG, LOPDGDD, AGG, Privacy Code Art. 113)

2.3 Analytical Framework: The Compliance Risk Score

Each country is scored 1–5 on three weighted dimensions:

Dimension	Weight	Measures
Enforcement Strictness	40%	Frequency and size of real fines/rulings found
Derogation Complexity	30%	How far national law diverges from GDPR baseline
Documentation Burden	30%	DPIA, pre-approval, or works-council requirements

$$\text{Compliance Risk Score} = (0.4 \times \text{Enforcement}) + (0.3 \times \text{Derogation}) + (0.3 \times \text{Documentation})$$

3 Compliance Risk Score — All 8 Countries

Country	Enforce.	Derog.	Docs	Score	Rating
France	5	5	5	5.0	Critical
Netherlands	5	4	4	4.4	Critical
Italy	4	4	3	3.7	High
Spain	4	3	3	3.4	High
Germany	3	3	3	3.0	High
Sweden	2	3	2	2.3	Moderate
Poland	2	2	2	2.0	Moderate
Ireland	1	1	2	1.3	Low

Table 1: Compliance Risk Score Ranking, June 2026

The Enforcement Spectrum: France and the Netherlands score highest not because their underlying GDPR obligations differ from other states, but because both layer additional national mechanisms — France’s CNIL pre-approval licensing and the Netherlands’ explicit “no consent override” doctrine — onto the EU baseline. Ireland’s low score does not mean low risk in principle; rather, the DPC’s enforcement focus has concentrated on consumer-facing Big Tech platforms rather than HR-specific employer conduct.

4 Category Deep-Dive: Biometric Data

Biometric data (fingerprint and facial recognition for attendance) is classified as “special category” data under Article 9 GDPR, carrying the highest baseline legal risk of any category tracked.

Country	Mechanism	Fine	Key Principle
Germany	Judicial review (case-by-case)	€0 (court ruling)	Fingerprint scan ruled unlawful; ID card was a less invasive alternative
Netherlands	Regulatory fine (after the fact)	€725,000	Consent invalid; no security/authentication necessity found
France	Pre-approval licensing	€10,000	Deployment requires CNIL approval <i>before</i> rollout; mandatory triennial DPIA

Table 2: Biometric Data — Three Enforcement Philosophies

Three Countries, Three Philosophies: Germany enforces *reactively* through courts after a dispute arises. The Netherlands enforces *reactively* through its regulator after deployment. France enforces *proactively* — requiring sign-off before a biometric system can be switched on at all. Identical underlying GDPR text produces three structurally different compliance pathways.

5 Category Deep-Dive: Employee Monitoring

Country	Mechanism	Fine	Key Principle
France	Regulatory fine, granular-metric scrutiny	€0 (under appeal)	Amazon’s scanner-based productivity indicators ruled excessive vs business need
Ireland	Guidance only	€0	Covert monitoring “generally unlawful”; DPIA/LIA recommended, not mandated
Sweden	Dignity & transparency test	€0 (no case found)	Covert monitoring banned outright; generic notice insufficient

Table 3: Employee Monitoring — Cross-Country Comparison

Hard Law vs Soft Law: France has issued an actual fine with detailed technical findings (specific scanner thresholds ruled disproportionate). Ireland and Sweden rely entirely on published guidance with no monitoring-specific fine identified in this audit — despite Sweden’s principles (dignity, anti-covert-monitoring) being arguably as strict as France’s in substance. **Strictness of written rule and strictness of enforcement are not the same thing.**

6 Category Deep-Dive: Health Data & Recruitment

6.1 Health/Sickness Data — Netherlands

Element	Finding
Fine	€15,000 (reduced from over €1,000,000 on grounds of company solvency)
Violation	Employer directly recorded illness type/cause — legally reserved for the occupational health service only
What employers MAY collect	Contact details, expected absence duration, current tasks, and whether the absence is accident-related
Consent status	Explicitly invalid even if freely offered — financial dependence voids consent as a legal basis

Table 4: Netherlands — CP&A Sick Leave Case

The Netherlands extends this principle even to **wearable device data** (steps, heart rate, sleep) — employers cannot access this data even with employee consent, reinforcing that special-category data sits structurally outside what consent can authorise in an employment relationship.

6.2 Recruitment Data — Spain, Poland, Germany

Country	Rule	Fine	Basis
Spain	Criminal record checks require specific legal authorisation — not consent, not legitimate interest	€2,000,000	LOPDGDD (stricter than GDPR baseline); polygraphs banned outright
Poland	Consent only, must be genuinely free; no penalty for refusal	€0	UODO guidance + Labour Code/Civil Code/GDPR triple liability
Germany	6-month maximum retention for rejected applicant data	€0	AGG (Equal Treatment Act) + BDSG §26

Table 5: Recruitment Data Across Three Jurisdictions

Spain’s €2 million fine is the largest in this entire repository, yet it stems from a single avoidable error: applying “legitimate interest” to criminal-record screening where Spanish law requires *specific statutory authorisation* instead. This is a clear, replicable compliance lesson — legal basis selection, not data volume, drove the size of this penalty.

7 Category Deep-Dive: Performance Records & Payroll

7.1 Performance & Disciplinary Records — Italy

Element	Finding
Fine	€420,000 (Garante, May 2025)
What happened	Employee's private WhatsApp messages, forwarded by co-workers, used as grounds for disciplinary action
Why it failed	Content was private, off-hours, and unrelated to job performance — employer's legitimate-interest claim failed the balancing test
Local derogation	Italian Privacy Code Art. 113 (+ Workers' Statute Art. 8) bars using off-duty personal content unrelated to professional aptitude in assessments or discipline
Extra penalty	Garante published the decision publicly — adding reputational damage to the fine

Table 6: Italy — WhatsApp Disciplinary Case

7.2 Payroll & Financial Data — Netherlands

Data Type	Retention Period
General personnel file	2 years post-employment
Wage tax declarations & salary records	7 years post-employment

Table 7: Netherlands — Dual Retention Regime

The Netherlands shows that **multiple laws can apply to the identical dataset simultaneously**. GDPR's storage-limitation principle would suggest short retention; Dutch tax law separately mandates 7 years for financial records. Employers must satisfy the longer of the two, not the GDPR default — a pattern likely to recur in any jurisdiction with strong parallel tax-retention statutes.

8 Retention Period Benchmark

Retention period is the single most numerically comparable metric across this repository.

Country	Data Type	Retention Period
Italy	Email metadata (Garante guideline)	21 days
Germany	Rejected applicant data	6 months
Netherlands	General personnel file	2 years
Netherlands	Payroll / wage tax records	7 years

Table 8: Retention Period Range Across Repository — 21 Days to 7 Years

A 118x range exists between the shortest and longest legally-grounded retention periods identified in this repository, for two entirely defensible reasons — data minimisation (Italy’s metadata rule) versus statutory tax obligation (Dutch payroll records). **There is no single “correct” HR data retention period** — it depends entirely on data type, country, and which competing law takes precedence.

9 Power BI Dashboard Overview

The accompanying interactive dashboard (`GDPR_Compliance_Dashboard.pbix`) translates this repository into four live visual components:

1. **KPI Cards** — Countries tracked (8), average compliance risk score, countries rated Critical (2), real fines identified (7)
2. **Compliance Risk Heatmap** — Matrix of Country $\times$ Data Category, colour-scaled from green (low risk) to red (critical), enabling instant visual identification of the highest-exposure combinations
3. **Fines Bar Chart** — Real GDPR fines by country in EUR, ranked descending, exposing Spain and the Netherlands as the largest financial exposure points
4. **Risk Score Ranking Chart** — All 8 countries ordered by Compliance Risk Score, conditionally coloured by risk band, with a category slicer enabling filtered views (e.g., “show only Biometric”)

The dashboard is designed for a practical use case: an HR or compliance lead operating across multiple EU entities can filter by data category and immediately see which countries demand pre-approval, which ban consent as a basis, and which carry active fine precedent — collapsing 12 rows of legal research into a single filterable view.

10 Strategic Recommendations

10.1 For a Company Operating HR Systems Across These 8 Countries

1. **Treat France and the Netherlands as default-block jurisdictions for biometric/health systems.** Priority: Critical

Any biometric attendance or health-data initiative should assume French pre-approval and Dutch “no consent override” rules apply by default, rather than discovering this after rollout.

2. **Standardise on legitimate-interest documentation, not consent, for employment data.** Priority: Critical

Across every country in this repository, consent was repeatedly ruled too weak a basis due to the employer-employee power imbalance. A documented legitimate-interest balancing test is the more defensible default basis.

3. **Apply a single conservative retention default, overridden only by statutory exceptions.** Priority: High

Default to short retention (e.g., 6 months for non-essential HR data) and explicitly flag the narrow categories — payroll, tax records — where longer statutory retention legally overrides the shorter default.

4. **Do not mistake Ireland’s low fine-count for low actual risk.** Priority: High

Ireland’s DPC has been overturned or strengthened by the EDPB in 7 of 8 reviewed decisions, suggesting under-enforcement rather than genuine leniency. Treat Irish HR data processing to the same documentation standard as higher-enforcement states.

5. **Build category-specific playbooks, not one GDPR policy.** Priority: Moderate

Biometric, health, monitoring, recruitment, performance, and payroll data each carry materially different legal bases and risk profiles — a single generic “GDPR policy” document is insufficient for multi-country HR operations.

11 Limitations & Conclusion

Limitations: This repository covers 12 country-category combinations out of a possible 48 (8 countries $\times$ 6 categories) — prioritising depth and real-case verification over exhaustive coverage. Three countries (Poland, Sweden, Ireland) show no HR-specific fine in this research, which may reflect genuinely lower enforcement activity or simply lower public reporting visibility rather than full compliance. Risk Score weightings (40/30/30) are an original analytical model, not an official regulatory ranking, and should be read as a structured comparison tool rather than a certified legal risk rating.

Conclusion: This audit set out to test whether “GDPR compliance” can be treated as one uniform standard across the EU. It cannot. Article 9(4)’s national-derogation clause means the same underlying regulation produces eight functionally distinct compliance regimes for HR data — from France’s proactive licensing model to Ireland’s reactive, guidance-led approach. **The core practical risk for any multi-country employer is not ignorance of GDPR itself, but assuming uniform application of it.** The Compliance Risk Score, fines benchmark, and category playbooks in this repository are designed to replace that assumption with a structured, evidence-based comparison.

Expand coverage to the remaining 36 country-category combinations, starting with the categories showing the widest variance identified here (biometric and health data). Layer in a fourth scoring dimension — “Enforcement Trend” — to capture whether each regulator’s activity is increasing or decreasing year-on-year, since several sources in this research (Spain’s 49% rise in labour complaints, Germany’s draft Employee Data Act) suggest the regulatory landscape is actively tightening.

12 Appendix: Complete Data Repository

Country	Category	Risk Score	Fine (EUR)	Source
Germany	Biometric	3.0	0	LAG Berlin-Brandenburg, 2020
Netherlands	Biometric	4.4	725,000	Dutch DPA (AP)
France	Biometric	5.0	10,000	CNIL, 2018
France	Employee Monitoring	5.0	0 (appeal)	CNIL, Amazon France
Ireland	Employee Monitoring	1.3	0	DPC Guidance 2023
Netherlands	Health/Sickness	4.4	15,000	Dutch DPA (AP), CP&A
Spain	Recruitment	3.4	2,000,000	AEPD
Poland	Recruitment	2.0	0	UODO Guidance
Italy	Performance/Disciplinary	3.7	420,000	Garante, May 2025
Sweden	Employee Monitoring	2.3	0	IMY Guidance
Netherlands	Payroll/Financial	4.4	0	Dutch DPA + Tax Admin.
Germany	Recruitment	3.0	0	AGG / BDSG §26

Table 9: Complete 12-Row Compliance Repository, June 2026

Prepared by: Ayaan Alam | Date: June 2026

Methodology: Manual legal/regulatory research + weighted risk scoring | Tools: Excel · Power BI · DAX · LaTeX

Independent academic analysis. All data sourced from publicly available regulatory and legal sources.